Kubernetes Health & Security Report

Prepared for **ACME GmbH (demo)**

kubemedic
read-only audit

Cluster
demo cluster
Date
2026-10-25 21:02 UTC
Prepared by
kubemedic · you@example.com
Scope
3 node(s), 24 workloads, 34 pods
Method
Read-only inspection of Kubernetes state. No changes were made to the cluster.

E

Critical issues need action now

11 crit 14 high

Executive summary

This report is the result of an automated, read-only inspection of the **ACME GmbH (demo)** Kubernetes cluster. It lists what is broken or at risk, why it matters, and how to fix it. Findings are produced by deterministic checks with evidence — not guesses — and every fix can be delivered as a reviewed change to your configuration, so nothing is applied to the cluster without your approval.

Top risks

Severity	Risk	Where
CRITICAL	Likely root cause: OpenSearch data/search is unhealthy	`DaemonSet/logging/fluent-bit`
CRITICAL	ingress-nginx ingress-nginx/ingress-nginx: controller 1.11.3 is vulnerable to IngressNightmare (CVE-2025-1974)	`Deployment/ingress-nginx/ingress-nginx-controller`
CRITICAL	Kong kong/kong: Admin API / Kong Manager is reachable from outside the cluster	`Deployment/kong/kong-gateway`
CRITICAL	Traefik kube-system/traefik-kube-system: dashboard/API enabled in insecure mode and exposed outside the cluster	`Deployment/kube-system/traefik`
CRITICAL	Likely root cause: Kafka data/events is unhealthy	`Deployment/shop/orders`
CRITICAL	Gateway shop/public is not serving traffic	`Gateway/shop/public`

Security

Workloads are scored by combining runtime alerts, image vulnerabilities, excessive privileges and exposure, and missing network isolation. Higher score = more urgent.

Deployment/shop/payment-api — SCORE 100 · CRITICAL

Deployment shop/payment-api: active suspicious runtime behaviour, critical CVEs in the running image, excessive privileges/exposure. LIKELY COMPROMISE — contain first

- Falco Critical: Drop and execute new binary in container (+40)
- 3 distinct Falco rules fired (+10)
- 1 critical CVE(s) in running image (+25)
- 'payment-api' may run as root (no runAsNonRoot/runAsUser) (+10)
- 'payment-api' allows privilege escalation (+5)
- no NetworkPolicy restricts ingress (+10)

DaemonSet/logging/fluent-bit

SCORE 40 · MEDIUM

DaemonSet logging/fluent-bit: excessive privileges/exposure.

- 'fluent-bit' may run as root (no runAsNonRoot/runAsUser) (+10)
- 'fluent-bit' allows privilege escalation (+5)
- mounts hostPath /var/log (+15)
- no NetworkPolicy restricts ingress (+10)

Deployment/ingress-nginx/ingress-nginx-controller

SCORE 40 · MEDIUM

Deployment ingress-nginx/ingress-nginx-controller: excessive privileges/exposure.

- 'controller' may run as root (no runAsNonRoot/runAsUser) (+10)
- 'controller' allows privilege escalation (+5)
- no NetworkPolicy restricts ingress (+10)
- reachable from outside the cluster via ingress-nginx-controller (LoadBalancer) (+15)

Deployment/kong/kong-gateway

SCORE 40 · MEDIUM

Deployment kong/kong-gateway: excessive privileges/exposure.

- 'proxy' may run as root (no runAsNonRoot/runAsUser) (+10)
- 'proxy' allows privilege escalation (+5)
- no NetworkPolicy restricts ingress (+10)
- reachable from outside the cluster via kong-admin (NodePort), kong-proxy (LoadBalancer) (+15)

StatefulSet/data/queue-server

SCORE 40 · MEDIUM

StatefulSet data/queue-server: excessive privileges/exposure.

- 'rabbitmq' may run as root (no runAsNonRoot/runAsUser) (+10)
- 'rabbitmq' allows privilege escalation (+5)
- no NetworkPolicy restricts ingress (+10)
- reachable from outside the cluster via queue-mgmt (NodePort) (+15)

StatefulSet/data/search

SCORE 40 · MEDIUM

StatefulSet data/search: excessive privileges/exposure.

- 'opensearch' may run as root (no runAsNonRoot/runAsUser) (+10)
- 'opensearch' allows privilege escalation (+5)
- no NetworkPolicy restricts ingress (+10)
- reachable from outside the cluster via search (LoadBalancer) (+15)

StrimziPodSet/data/events-broker

SCORE 30 · MEDIUM

StrimziPodSet data/events-broker: excessive privileges/exposure.

- 'kafka' may run as root (no runAsNonRoot/runAsUser) (+10)
- 'kafka' allows privilege escalation (+5)
- reachable from outside the cluster via events-kafka-external-bootstrap (LoadBalancer) (+15)

DaemonSet/logging/promtail

SCORE 25 · MEDIUM

DaemonSet logging/promtail: excessive privileges/exposure.

- 'promtail' may run as root (no runAsNonRoot/runAsUser) (+10)
- 'promtail' allows privilege escalation (+5)
- no NetworkPolicy restricts ingress (+10)

Deployment/istio-system/istiod

SCORE 25 · MEDIUM

Deployment istio-system/istiod: excessive privileges/exposure.

- 'istiod' may run as root (no runAsNonRoot/runAsUser) (+10)
- 'istiod' allows privilege escalation (+5)
- no NetworkPolicy restricts ingress (+10)

Deployment/mesh-demo/details-v1

SCORE 25 · MEDIUM

Deployment mesh-demo/details-v1: excessive privileges/exposure.

- 'details' may run as root (no runAsNonRoot/runAsUser) (+10)
- 'details' allows privilege escalation (+5)
- no NetworkPolicy restricts ingress (+10)

Explicit points per signal (see docs/scoring.md); x1.5 when runtime alerts co-occur with exploitable CVEs or excessive exposure. 70+ critical, 45+ high, 25+ medium.

Reliability & root causes

Failures are traced to their real cause across layers (an app failing because a data system or dependency it relies on is unhealthy), so you fix the source rather than the symptom.

Likely root cause: OpenSearch data/search is unhealthy

CRITICAL

`DaemonSet/logging/fluent-bit`

fluent-bit depends on OpenSearch data/search, which currently reports: OpenSearch data/search is down (0/1 ready). Fix the dependency first; restarting or changing fluent-bit will not help.

`dependency` · fluent-bit uses OpenSearch data/search via Service search (env output:opensearch)
`component` · [critical] OpenSearch data/search is down (0/1 ready)

Recommended action: Run diagnose_component on OpenSearch data/search

Likely root cause: Kafka data/events is unhealthy

CRITICAL

`Deployment/shop/orders`

orders depends on Kafka data/events, which currently reports: Kafka data/events: min.insync.replicas (3) leaves no room for a broker failure (replication factor 3); Kafka data/events is degraded (2/3 ready). Fix the dependency first; restarting or changing orders will not help.

`dependency` · orders uses Kafka data/events via Service events-kafka-bootstrap (env KAFKA_BOOTSTRAP_SERVERS)
`component` · [critical] Kafka data/events: min.insync.replicas (3) leaves no room for a broker failure (replication factor 3)
`component` · [high] Kafka data/events is degraded (2/3 ready)
`component` · [high] Kafka data/events: the Strimzi operator reports a problem

Recommended action: Run diagnose_component on Kafka data/events

Likely root cause: OpenSearch data/search is unhealthy

CRITICAL

`Deployment/shop/orders`

orders depends on OpenSearch data/search, which currently reports: OpenSearch data/search is down (0/1 ready). Fix the dependency first; restarting or changing orders will not help.

`dependency` · orders uses OpenSearch data/search via Service search (env SEARCH_URL)
`component` · [critical] OpenSearch data/search is down (0/1 ready)

Recommended action: Run diagnose_component on OpenSearch data/search

Gateway shop/public is not serving traffic

CRITICAL

`Gateway/shop/public`

The Gateway is not Accepted/Programmed by its controller, so none of its listeners receive traffic (often: no address assigned, invalid GatewayClass, controller down).

`status` · Programmed=False AddressNotAssigned: No addresses have been assigned to the Gateway

OpenSearch data/search is down (0/1 ready)

CRITICAL

`StatefulSet/data/search`

No OpenSearch member is ready. Every client of this OpenSearch is affected.

`pod-status` · search-0: CrashLoopBackOff, last exit: OOMKilled (restarts=6)

Alertmanager monitoring/main is not available

HIGH

`Alertmanager/monitoring/main`

The Prometheus operator reports it unavailable: alerts are not routed to anyone.

`status` · Available=False NoPodReady: 0/1 pods ready: alertmanager-main-0 CrashLoopBackOff (invalid config: missing receiver 'pagerduty')

Argo CD app data-tier: sync is failing

HIGH

`Application/argocd/data-tier`

Argo CD cannot apply Git to namespace data: merged changes (including fixes) are not reaching the cluster.

`argocd` · sync=OutOfSync health=Degraded lastOperation=Failed

`argocd` · operation: one or more objects failed to apply, reason: PersistentVolumeClaim "data-events-broker-2" is invalid: spec: Forbidden: spec is immutable after creation

Velero backup location default is unavailable

HIGH

`BackupStorageLocation/velero/default`

Velero cannot reach the object storage: backups fail and restores are impossible.

`velero` · BackupStorageLocation "default" is unavailable: rpc error: code = Unknown desc = AccessDenied: Access Denied

Certificate shop/shop-tls expires in 2 day(s)

HIGH

`Certificate/shop/shop-tls`

cert-manager normally renews well before expiry (default: at 2/3 of the lifetime); a certificate this close to expiry means renewal is failing.

`cert-manager` · dnsNames: shop.example.com

`cert-manager` · notAfter: 2026-10-26T08:00:00+00:00

`cert-manager` · renewal failing: The certificate request has failed to complete and will be retried: Failed to wait for order resource "shop-tls-1-2735" to become ready: order is in "errored" state: Failed to finalize Order: 429 urn:ietf:params:acme:error:rateLimited

Recommended action: kubectl describe certificate -n shop shop-tls; check the Order/Challenge resources and the issuer

CrashLoopBackOff: 'cilium-agent' keeps exiting

HIGH

`DaemonSet/kube-system/cilium`

Container 'cilium-agent' starts and exits repeatedly. Exit code None: unknown.

`pod-status` · cilium-cx2q/cilium-agent: CrashLoopBackOff, last exit code None (CrashLoopBackOff), restarts=0

Recommended action: Check previous logs: kubectl logs -n kube-system cilium-cx2q -c cilium-agent --previous

Cilium kube-system/cilium is degraded (2/3 ready)

HIGH

`DaemonSet/kube-system/cilium`

1 of 3 members are not ready; redundancy is reduced and a further failure may cause an outage. Pods on affected nodes lose networking and policy enforcement.

`pod-status` · cilium-cx2q: CrashLoopBackOff (restarts=0)

Fluent Bit logging/fluent-bit: logs are not being delivered to OpenSearch data/search (down)

HIGH

`DaemonSet/logging/fluent-bit`

Fluent Bit logging/fluent-bit ships logs to OpenSearch data/search via Service search (opensearch output), which is down: OpenSearch data/search is down (0/1 ready). Logs are buffered and, once retries or buffers run out, dropped. Fix the destination first.

`dependency` · output opensearch -> search

`component` · OpenSearch data/search is down (0/1 ready)

Recommended action: Run diagnose_component on OpenSearch data/search

'proxy' is at 95% of its memory limit (OOM risk)

HIGH

`Deployment/kong/kong-gateway`

Pod kong-gateway-5f6c7d8b9-abcd1 currently uses 975Mi of a 1Gi limit. One more allocation spike and the kernel kills it (OOMKilled). Raise the limit or reduce memory use.

`metrics-server` · kong-gateway-5f6c7d8b9-abcd1/proxy: 975Mi used, limit 1Gi

Fix available as a GitOps change: Raise memory limit of 'proxy' to 1536Mi

ratings-v1: istio-proxy sidecar is not ready

HIGH

`Deployment/mesh-demo/ratings-v1`

The mesh proxy is not ready, so traffic to and from the pod fails even if the app is healthy (control plane unreachable, certificate or config error).

`pod-status` · ratings-v1-6b7c8d9e0-r1/istio-proxy: Running

OOMKilled: 'checkout' exceeds its memory limit

HIGH

`Deployment/shop/checkout`

Container 'checkout' is being killed by the kernel OOM killer: it exceeds its memory limit (256Mi). 2 pod(s) affected, 12 restarts total. The latest rollout (revision 2) lowered the memory limit from 512Mi to 256Mi — this is the most likely cause.

`pod-status` · checkout-7c9d4f8b6-abcde/checkout: last terminated OOMKilled (exit 137), restarts=7

`pod-status` · checkout-7c9d4f8b6-fghij/checkout: last terminated OOMKilled (exit 137), restarts=5

`rollout` · revision 2 (checkout-7c9d4f8b6) rolled out; changes: checkout: image registry.example.com/shop/checkout:2.7.4 → registry.example.com/shop/checkout:2.8.0; checkout: memory request 256Mi → 128Mi; checkout: memory limit 512Mi → 256Mi

Fix available as a GitOps change: Set memory limit of 'checkout' to 512Mi (currently 256Mi)

Configuration & hardening

Kafka data/events: min.insync.replicas (3) leaves no room for a broker failure (replication factor 3)

CRITICAL

`Kafka/data/events`

Producers using acks=all fail as soon as one replica is unavailable (rolling restarts included). Use min.insync.replicas = replication factor - 1 (typically RF 3, ISR 2). Right now only 2 brokers are ready, so writes are already failing with NotEnoughReplicas.

Fix available as a GitOps change: Set min.insync.replicas to 2 in the Kafka resource

OpenSearch data/search: JVM heap (1Gi) is not smaller than the memory limit (1Gi)

CRITICAL

`StatefulSet/data/search`

The heap alone fills the container's memory; with thread stacks, metaspace and direct buffers the kernel will OOM-kill the JVM under load.

Fix available as a GitOps change: Raise the memory limit to 2Gi (or lower the heap)

CreateContainerConfigError: 'api' cannot start

HIGH

`Deployment/shop/api`

Container 'api' references secret 'api-db-credentials' which does not exist in namespace 'shop'. Create it (e.g. via your secrets manager / External Secrets) or fix the reference.

`pod-status` · api-7d8e9f0a1-z9x8c/api: secret "api-db-credentials" not found

`event` · Failed on Pod/api-7d8e9f0a1-z9x8c (x11): Error: secret "api-db-credentials" not found

Recommended action: Provide secret 'api-db-credentials' in namespace 'shop' (kubemedic never creates secrets)

Additional security findings

ingress-nginx ingress-nginx/ingress-nginx: controller 1.11.3 is vulnerable to IngressNightmare (CVE-2025-1974)

CRITICAL

`Deployment/ingress-nginx/ingress-nginx-controller`

CVE-2025-1974 (CVSS 9.8) lets anything that can reach the admission webhook run code in the controller, which can read every Secret in the cluster. Fixed in v1.11.5 and v1.12.1. Until upgraded, restrict access to the admission webhook with a NetworkPolicy.

`image` · registry.k8s.io/ingress-nginx/controller:v1.11.3@sha256:d56f135b6462cfc476447cfe564b83a45e8bb7da2774963b00d12161112270b7

Fix available as a GitOps change: Upgrade the controller image to v1.11.5 or later

Kong kong/kong: Admin API / Kong Manager is reachable from outside the cluster

CRITICAL

`Deployment/kong/kong-gateway`

The Kong Admin API can create routes, plugins and consumers: whoever reaches it controls all traffic through the gateway (and can read credentials of consumers). Keep it ClusterIP and reach it with port-forward or behind authentication.

`service` · kong-admin: NodePort, ports 8001

Fix available as a GitOps change: Change the admin Service type to ClusterIP

Traefik kube-system/traefik-kube-system: dashboard/API enabled in insecure mode and exposed outside the cluster

CRITICAL

`Deployment/kube-system/traefik`

--api.insecure=true serves the Traefik dashboard and API on the `traefik` entrypoint (port 8080) without authentication, revealing every route, backend and middleware. A LoadBalancer/NodePort Service publishes it.

`service` · traefik: LoadBalancer

Fix available as a GitOps change: Make the dashboard Service internal

OpenSearch data/search is reachable from outside the cluster

CRITICAL

`StatefulSet/data/search`

Service(s) search expose the OpenSearch client port through LoadBalancer. Authentication is disabled, so anyone who can reach it can read and change data.

`service` · search: type=LoadBalancer, ports=9200

Fix available as a GitOps change: Change the Service type to ClusterIP (or restrict loadBalancerSourceRanges)

ingress-nginx ingress-nginx/ingress-nginx: snippet annotations are allowed

HIGH

`Deployment/ingress-nginx/ingress-nginx-controller`

allow-snippet-annotations=true lets anyone who can create an Ingress inject raw NGINX config (the root of several ingress-nginx CVEs), e.g. to read the controller's credentials. The default is false since v1.9.

`config` · allow-snippet-annotations: true

Kong kong/kong: Admin API listens on all interfaces over plain HTTP

HIGH

`Deployment/kong/kong-gateway`

KONG_ADMIN_LISTEN binds the Admin API to 0.0.0.0:8001 without TLS and no NetworkPolicy limits who can connect, so any pod in the cluster can reconfigure the gateway.

`env` · KONG_ADMIN_LISTEN includes 0.0.0.0:8001 (no ssl)

Kong kong/kong: Ingress shop/orders-api references missing KongPlugin key-auth

HIGH

`Deployment/kong/kong-gateway`

The policy this route expects (authentication, rate limiting, …) is not in effect because no KongPlugin or KongClusterPlugin named key-auth exists.

Platform components

Status	Component	Layer	Issues	Main problem
DOWN	OpenSearch data/search	Data systems	6	OpenSearch data/search is down (0/1 ready)
DEGRADED	Kafka data/events	Data systems	6	Kafka data/events: min.insync.replicas (3) leaves no room for a broker failure (replication factor 3)
DEGRADED	Fluent Bit logging/fluent-bit	Logging pipeline	5	Fluent Bit logging/fluent-bit: logs are not being delivered to OpenSearch data/search (down)
DEGRADED	Cilium kube-system/cilium	Networking	1	Cilium kube-system/cilium is degraded (2/3 ready)
AT-RISK	ingress-nginx ingress-nginx/ingress-nginx	Edge & ingress	6	ingress-nginx ingress-nginx/ingress-nginx: controller 1.11.3 is vulnerable to IngressNightmare (CVE-2025-1974)
AT-RISK	RabbitMQ data/queue	Data systems	5	RabbitMQ data/queue admin/cluster port is exposed outside the cluster
AT-RISK	Kong kong/kong	Edge & ingress	4	Kong kong/kong: Admin API / Kong Manager is reachable from outside the cluster
AT-RISK	Redis data/cache	Data systems	3	Redis data/cache accepts connections without a password
AT-RISK	Traefik kube-system/traefik-kube-system	Edge & ingress	2	Traefik kube-system/traefik-kube-system: dashboard/API enabled in insecure mode and exposed outside the cluster
HEALTHY	CoreDNS kube-system/coredns	Networking	1	CoreDNS kube-system/coredns: a single replica serves all cluster DNS
HEALTHY	Promtail logging/promtail	Logging pipeline	1	Promtail logging/promtail: Promtail is end of life (March 2, 2026)
HEALTHY	Istio (istiod) istio-system/istio	Service mesh	0	None
HEALTHY	metrics-server kube-system/metrics-server	Monitoring	0	None
HEALTHY	PostgreSQL data/pg	Data systems	0	None

Routing, certificates & platform issues

Severity	Area	Issue
CRITICAL	routing	Gateway shop/public is not serving traffic
HIGH	routing	Ingress shop/storefront: shop.example.com/ has no ready backend (frontend)
HIGH	routing	Ingress shop/storefront routes shop.example.com/checkout to missing Service checkout-svc
HIGH	routing	Ingress shop/orders-api: api.example.com/orders has no ready backend (orders)
HIGH	tls	Certificate shop/shop-tls expires in 2 day(s)
HIGH	routing	Gateway shop/public: listener https is broken
HIGH	routing	HTTPRoute data/reviews is not attached to Gateway public
HIGH	routing	HTTPRoute data/reviews: backend reference cannot be resolved
HIGH	routing	HTTPRoute data/reviews routes reviews.example.com to missing Service reviews
HIGH	routing	IngressRoute shop/admin routes Host(`admin.example.com`) to missing Service admin-ui
HIGH	routing	IngressRoute shop/admin uses missing Middleware basic-auth
HIGH	gitops	Argo CD app data-tier: sync is failing
HIGH	gitops	Flux Kustomization flux-system/platform is failing
HIGH	gitops	Flux GitRepository flux-system/infra is failing
HIGH	secrets	ExternalSecret shop/api-db-credentials cannot sync
HIGH	secrets	SealedSecret shop/payment-keys cannot be decrypted
HIGH	autoscaling	HPA checkout cannot read its metrics and is not scaling
HIGH	autoscaling	HPA frontend is pinned at maxReplicas (1)
HIGH	autoscaling	KEDA ScaledObject shop/worker-queue is not ready
HIGH	autoscaling	Karpenter NodePool default reached its cpu limit
HIGH	autoscaling	Karpenter NodeClaim default-x7k2p failed to launch
HIGH	autoscaling	Cluster Autoscaler will not add a node for worker
HIGH	storage	PVC data/data-events-broker-2 uses missing StorageClass fast-ssd
HIGH	policy	Deployment shop/payment-api fails 1 policy check(s)
HIGH	policy	Pods of recommendations are blocked by admission policy
HIGH	backup	Velero backup location default is unavailable
HIGH	monitoring	Alertmanager monitoring/main is not available
HIGH	alerts	Alert firing: KafkaUnderReplicatedPartitions
HIGH	nodes	Node kind-worker2: kubelet is more than 3 minor versions behind
HIGH	routing	LoadBalancer Service shop/partner-api has no external address

Capacity & cost

Resource	Requested	In use	Idle (paid, unused)
CPU	1100m	1395m	0m
Memory	2816Mi	2036Mi	780Mi

Current usage from metrics-server, not a peak. Idle requests are capacity you pay for but don't use.

Method & scope

kubemedic read the cluster's state through the Kubernetes API using a **read-only** identity. It cannot create, change or delete

resources, and does not read Secret contents. Environment values and config data are processed in memory and never stored or reproduced in this report (only names are shown). This is a configuration and state review: it does not connect to your applications or run live traffic tests.

Generated by kubemedic — Kubernetes health & security audit. © 2026 kubemedic. This report reflects the cluster state at the time of capture (2026-10-23T10:00:00+00:00).